

Project 3: Identifying and Analyzing Threats, Vulnerabilities, and Exploits

Cole Dombrowski - MISY 5325

1. Project 2 Continuity and Changes

Project 3 builds on the assets and business activities identified in Project 2. The primary areas of concern are the EHR Core, Telehealth Cloud Platform, Billing and Claims, and Core Network Infrastructure. The EHR supports clinical operations and patient information. Telehealth introduces cloud, API, vendor, and remote-device dependencies. Billing and claims contain financial, insurance, and patient-related information. Core network infrastructure connects SCHN's facilities, users, and systems (Gibson & Igonor, 2020).

The Microsoft 365 incident increases the priority of billing-related identities and cloud communications. However, there is currently no evidence that the EHR was accessed through the compromised account, so this remains an investigation item rather than an established compromise.

2. Threat Identification

Microsoft 365 account compromise: An attacker could use stolen credentials to access a billing employee's mailbox, monitor communications, conduct additional phishing, or attempt fraud. The scenario confirms successful credential entry and an unfamiliar subsequent login.

Internal or trusted-user phishing: A compromised employee account could be used to send convincing messages to other SCHN employees, potentially leading to additional credential compromise or information disclosure.

Telehealth SaaS/API compromise: A vulnerability involving the telehealth provider, APIs, or integrations could expose or disrupt telehealth information and connected SCHN systems.

Ransomware: An attacker could compromise an endpoint or account and attempt to spread to network-connected systems, disrupting clinical and administrative operations.

Accidental information disclosure: Employees could unintentionally send patient, insurance, or financial information to an incorrect recipient or improperly share information.

Severe environmental disruption: Hurricanes, flooding, storm surge, or power loss could damage facilities or infrastructure and interrupt SCHN operations (Gibson & Ignor, 2020).

3. Vulnerability Analysis

Microsoft 365: The incident shows that employee credentials could be compromised through a spoofed sign-in page. The effectiveness of MFA, Conditional Access, session controls, and mailbox-forwarding restrictions requires verification (Gibson & Ignor, 2020).

Employee accounts: Because employees use internal email to communicate about patients, insurance, and business operations, inadequate phishing resistance or email security could allow compromised accounts to be used to target other SCHN employees. These controls, along with session-revocation controls, should be verified.

Telehealth: Telehealth depends on external services and API integrations. API authentication, service-account permissions, vendor security controls, and monitoring are not established and require verification.

Network and endpoints: Clinical and administrative endpoints connect to SCHN's broader network and systems. Patching, segmentation, endpoint protection, and administrative controls could affect exposure to ransomware and lateral movement and require verification.

Data handling: Employees handle patient, insurance, and financial information as part of billing and claims activities. Data-handling procedures and DLP controls should be verified to determine the potential for accidental disclosure.

Physical infrastructure: SCHN's coastal environment creates exposure to flooding, storms, and power disruptions. Equipment protection, backup power, and alternate processing capabilities require verification.

4. Threat–Vulnerability–Exploit Analysis: See Table 1 below

5. Deeper Analysis of Three Priority Exposure Paths

Microsoft 365 Account Compromise: The compromised billing account could expose insurance, patient-related, financial, and internal communications. The attacker obtained access after the employee entered credentials into a spoofed sign-in page, followed by an unfamiliar login and mailbox forwarding rule. If authentication and mailbox protections are insufficient, the account could be used for information collection, fraud, or additional phishing. Potential consequences include unauthorized disclosure of sensitive information and disruption of billing communications.

Telehealth/API Compromise: Telehealth depends on external services and system integrations. Weak authentication, excessive permissions, or inadequate vendor controls could allow unauthorized access to telehealth information or connected systems. Exploitation could affect the confidentiality, integrity, or availability of services supporting patient care (Gibson & Igonor, 2020). The extent of SCHN's exposure depends on its API architecture, permissions, and vendor controls.

Ransomware and Network Compromise: A compromised endpoint or account could provide an entry point into SCHN's network. Insufficient segmentation, patching, endpoint protection, or administrative controls could allow an attacker to reach additional systems. Potential consequences include loss of access to clinical and administrative systems, disruption of patient-care activities, and interruption of billing or other business operations.

6. Microsoft 365 Incident Analysis

Threats: Credential phishing, unauthorized account access, business email compromise, and potential follow-on phishing.

Vulnerabilities: The employee entered credentials into a spoofed page, followed by an unfamiliar Microsoft 365 login. MFA, Conditional Access, session controls, and mailbox-forwarding protections remain to be verified.

Successfully exploited: The phishing page successfully induced credential entry, followed by an unfamiliar Microsoft 365 login and creation of a forwarding rule.

Potentially affected: Billing and claims, insurance communications, patient-related information, and internal communications. There is currently no evidence that the EHR was accessed.

Known: Credentials were entered into a spoofed page, an unfamiliar login occurred, a forwarding rule was created, and the password was reset.

Reasonably inferred: The credentials were likely obtained and used by an unauthorized party. The forwarding rule may indicate an attempt to access or monitor mailbox communications.

Unknown: Whether information was accessed or removed, where the mailbox forwarded messages, what messages were accessed, and whether other accounts were targeted.

7. Priority Information Gaps

1. **Microsoft 365 controls:** Determine the MFA, Conditional Access, session, and mailbox-forwarding controls currently enabled.
2. **Telehealth architecture:** Determine API authentication, permissions, integrations, vendor controls, and monitoring.
3. **Centralized logging:** Determine what Microsoft 365, endpoint, network, and telehealth activity is logged and correlated (Gibson & Igonor, 2020).

8. Preparation for Project 4

Three threat-vulnerability combinations should proceed to formal assessment (Gibson & Igonor, 2020):

1. **Microsoft 365 credential compromise and mailbox abuse:** The incident provides evidence of successful credential use and unresolved questions about potential information exposure.
2. **Telehealth API compromise affecting connected systems:** Telehealth relies on third-party and API dependencies that could affect patient-care services if compromised.
3. **Ransomware through endpoint or network compromise:** A successful compromise could disrupt access to multiple clinical and administrative systems.

Table 1. Threat–Vulnerability–Exploit Analysis

Asset or Business Activity	Threat	Relevant Vulnerability	Potential Exploit or Attack Path	C/I/A Affected	Potential Organizational Consequence	Scenario Evidence or Assumption
Billing and claims communications	Microsoft 365 account compromise	Authentication and mailbox protections require verification	Phishing captures credentials; attacker signs in and creates forwarding rule	C, I	Unauthorized access, fraud, or additional phishing	Credential entry, unfamiliar login, and forwarding rule confirmed
Employee accounts and internal communications	Internal/trusted-user phishing	Employee accounts and internal trust can be abused after compromise	Compromised account sends convincing internal messages	C, I	Additional credential compromise or disclosure	Threat scenario; controls require verification
Telehealth platform and connected systems	Third-party/API compromise	API permissions, authentication, and vendor controls require verification	Compromise of vendor service or API provides unauthorized access	C, I, A	Exposure or disruption of telehealth services/information	Architecture and permissions are information gaps
Core network and endpoints	Ransomware	Patching, segmentation, endpoint protection, and administrative controls	Compromised endpoint/account used to reach additional systems	C, I, A	Disruption of clinical and administrative operations	Threat scenario; controls unverified

		require verification				
Patient, insurance, and financial information	Accidental disclosure	Data-handling and DLP processes require verification	Information sent to unintended recipient or improperly shared	C	Unauthorized disclosure	Threat scenario; DLP controls unknown
Facilities and supporting infrastructure	Severe weather/environmental disruption	Physical protection, backup power, and alternate processing require verification	Storm, flooding, or power loss disrupts equipment/facilities	A	Interruption of systems and business activities	Coastal environment supports relevance

References

Gibson, D., & Igonor, A. (2020). *Managing risk in information systems* (3rd ed.).